Anlage B – Vertrag zur Auftragsverarbeitung (AVV) gemäß Art. 28 DSGVO

Stand: Oktober 2026

Dieser Vertrag zur Auftragsverarbeitung (nachfolgend "AVV") ist Anlage B zum Rahmenvertrag zwischen den nachstehenden Parteien und konkretisiert die datenschutzrechtlichen Pflichten bei der Verarbeitung personenbezogener Daten im Auftrag.

Parteien

Auftragsverarbeiter: NexAI – Next Generation Artificial Intelligence GbR, Untere Bergstraße 13, 74586 Frankenhardt-Honhardt, Deutschland, vertreten durch die Gesellschafter Maximilian Trenk und Jason Brian Merklein, jeder allein (§ 720 Abs. 2 BGB), oder durch eine bevollmächtigte Person (Ziffer 16 des Leistungsscheins), E-Mail mbt@nex-a-i.com, Telefon 0176 80714816 — nachfolgend "NexAI".

Verantwortlicher (Kunde):

Firma / Rechtsform: _____

Anschrift: _____

Vertreten durch: _____

E-Mail: _____

Telefon: _____

— nachfolgend "Kunde". NexAI und der Kunde nachfolgend gemeinsam "Parteien", einzeln "Partei".

§ 1 Präambel, Gegenstand und Rollenverteilung

(1) NexAI erbringt für den Kunden Leistungen im Zusammenhang mit der Bereitstellung und dem Betrieb KI-gestützter Agenten (Voice Agent, Chat Agent, Automatisierungen, individuelle KI-Agenten – nachfolgend "Agenten") sowie von Softwareanwendungen (NexAI CRM, NexAI Kalender, NexAI Mailagent, individuelle Anwendungen – nachfolgend "Anwendungen") und zugehöriger Projekt- und Betriebsleistungen. Im Rahmen dieser Leistungen verarbeitet NexAI personenbezogene Daten im Auftrag des Kunden. Betreibt der Kunde eine Anwendung als Kauflizenz selbst (Anlage E), verarbeitet NexAI personenbezogene Daten nur bei Wartungs- und Supportzugriffen; nur insoweit gilt dieser AVV.

(2) Der Kunde ist hinsichtlich der im Auftrag verarbeiteten personenbezogenen Daten **Verantwortlicher** im Sinne des Art. 4 Nr. 7 DSGVO. NexAI ist insoweit **Auftragsverarbeiter** im Sinne des Art. 4 Nr. 8 DSGVO und verarbeitet die Daten ausschließlich weisungsgebunden nach Maßgabe dieses AVV.

(3) Gegenstand dieses AVV ist die Konkretisierung der datenschutzrechtlichen Rechte und Pflichten der Parteien nach Art. 28 DSGVO. Die Zuordnung der Rolle von NexAI je Leistungsart ergibt sich aus der Rollenmatrix in § 15.

(4) Bei Widersprüchen zwischen diesem AVV und den übrigen Vertragsdokumenten (Rahmenvertrag, Auftragsformular/Leistungsschein, Anlage A, Anlage C, Anlage D, AGB) gehen in **datenschutzrechtlichen Fragen** die Regelungen dieses AVV vor (Sachvorrang). Im Übrigen

gelten die Regelungen des Rahmenvertrags und seiner Anlagen fort.

(5) Die eigene straf-, ordnungswidrigkeiten- und bußgeldrechtliche Verantwortlichkeit von NexAI sowie eine etwaige eigene datenschutzrechtliche Verantwortlichkeit von NexAI für Zwecke, die NexAI selbst bestimmt, bleiben von diesem AVV unberührt.

§ 2 Art, Umfang, Zweck und Dauer der Verarbeitung

(1) **Art der Verarbeitung:** Erheben, Erfassen, Organisieren, Speichern, Anpassen, Auslesen, Abfragen, Verwenden, Übermitteln, Bereitstellen, Kombinieren, Einschränken und Löschen personenbezogener Daten mittels automatisierter Verfahren im Rahmen des Betriebs der Agenten und Anwendungen (u. a. Sprachdialog, Chatdialog, Terminvereinbarung und Terminverwaltung, Weiterleitung, Automatisierungen, Verwaltung von Kontakt-, Vorgangs- und Aufgabendaten, Versand von Bestätigungen und Erinnerungen; beim NexAI Mailagent zusätzlich Abruf und Spiegelung der Nachrichten aus den vom Kunden benannten Postfächern, ihre Einstufung, Zusammenfassung und Prüfung auf Betrugsmerkmale mittels eines Sprachmodells, das Erkennen von Fristen, Terminen und Rechnungen, das Erstellen von Antwortentwürfen, deren Versand nach Freigabe sowie die Protokollierung der Freigaben).

(2) **Zweck der Verarbeitung:** Bereitstellung, Einrichtung, Betrieb, Wartung und Support der Agenten und Anwendungen für den Kunden, insbesondere die Beantwortung von Anfragen von Endnutzern, die Vereinbarung, Verwaltung und Bestätigung von Terminen, die Weiterleitung von Anliegen sowie die Verwaltung der Kontakt-, Vorgangs- und Aufgabendaten des Kunden in den beauftragten Anwendungen. Beim NexAI Mailagent ist Zweck die Unterstützung des Kunden bei der Bearbeitung seiner geschäftlichen E-Mail-Korrespondenz.

(3) **Umfang der Verarbeitung:** bestimmt sich nach den im Auftragsformular/Leistungsschein und in Anlage A (Leistungsbeschreibung) festgelegten Agenten, Anwendungen und Funktionen sowie nach den dokumentierten Weisungen des Kunden.

(4) **Dauer der Verarbeitung:** Die Verarbeitung beginnt mit der Aufnahme der Leistungserbringung und endet mit Beendigung des Rahmenvertrags bzw. der jeweiligen Leistung, vorbehaltlich der Regelungen zu Löschung und Rückgabe (§ 12) und etwaiger gesetzlicher Aufbewahrungspflichten. Dieser AVV gilt für die Dauer der Verarbeitung personenbezogener Daten im Auftrag.

§ 3 Kategorien betroffener Personen und personenbezogener Daten

Gegenstand der Verarbeitung sind – abhängig von den beauftragten Agenten und Anwendungen – die folgenden Kategorien:

3.1 Kategorien betroffener Personen

- Ansprechpartner, Beschäftigte und Vertreter des Kunden (Nutzer der Verwaltungs-/Konfigurationsfunktionen, Kontaktpersonen);
- **Endnutzer** – Personen, die mit den Agenten oder Anwendungen interagieren, insbesondere Anrufer (Voice Agent), Chat-Kontakte (Chat Agent), Personen, die einen Termin buchen (NexAI Kalender), sowie Nutzerinnen und Nutzer einer für den Kunden betriebenen Anwendung (NexAI App);
- Kontakte, Interessenten und Kundschaft des Kunden, deren Daten der Kunde in den beauftragten Anwendungen speichert oder die aus den Agenten dorthin übernommen werden (NexAI CRM, NexAI Kalender);

- Dritte, deren Daten von Endnutzern im Verlauf einer Interaktion oder in einem Freitextfeld mitgeteilt werden (z. B. genannte Kontaktpersonen);
- Absender, Empfänger und in Nachrichten oder Anhängen genannte Personen der über den NexAI Mailagent bearbeiteten Korrespondenz, insbesondere Kunden, Interessenten, Lieferanten, Behörden, Bewerber, Beschäftigte des Kunden und sonstige Dritte.

3.2 Kategorien personenbezogener Daten

- Kontakt- und Stammdaten (Name, Anrede, Firma/Funktion, Telefonnummer, E-Mail-Adresse, Anschrift);
- Gesprächs- und Kommunikationsinhalte (Inhalte von Anrufen, Chats, Nachrichten);
- Wortprotokolle (Transkripte) und – nur bei ausdrücklich aktivierter Funktion – Tonaufzeichnungen von Gesprächen;
- Termindaten (Terminwünsche, Datum/Uhrzeit, Anlass, Status);
- Anliegen-, Vorgangs- und Statusdaten (Anfrage, Kategorie, Ergebnis, Weiterleitung);
- Auftrags-, Vorgangs- und Belegdaten, soweit der Kunde solche in einer Anwendung führt (z. B. Leistung, Betrag, Status);
- Notizen und Freitexte, die der Kunde oder Endnutzer in einer Anwendung erfassen;
- Zugangs- und Protokolldaten der Nutzerkonten des Kunden (Anmeldedaten – Passwörter ausschließlich als Prüfsumme –, Sitzungen, Änderungsprotokoll);
- Metadaten und technische Daten (Verbindungs-/Nutzungsdaten, Zeitstempel, Kennungen, Kanal, Dauer, technische Protokolldaten);
- beim NexAI Mailagent: vollständiger Inhalt von Nachrichten und Anhängen, Kopf- und Verkehrsdaten, in der Korrespondenz enthaltene Zahlungsdaten (insbesondere Bankverbindungen) sowie die vom System erzeugten Bewertungen (Einstufung, Zusammenfassung, Tonfall, Betrugsbewertung, erkannte Fristen und Rechnungen), Antwortentwürfe, das Freigabeprotokoll (Person, Zeitpunkt, Aktion, Betreff, Wortlaut, Prüfsumme), das Verwaltungsprotokoll und zu selbsttätig versandten Antworten Empfänger, Betreff und Message-ID (Schleifenschutz); ferner Name, Anmeldeadresse und Rolle der vom Kunden angelegten Personen und die ihnen zugeordneten Postfächer, ein Abdruck des Passworts, das verschlüsselt gespeicherte Geheimnis des zweiten Faktors, offene Sitzungen, Zuweisungen, interne Notizen und Abwesenheiten mit Vertretung sowie die verschlüsselt gespeicherten Zugangsdaten zu den Postfächern des Kunden.

Besondere Kategorien personenbezogener Daten (Art. 9 DSGVO) sind nicht Gegenstand der beauftragten Verarbeitung, soweit nachstehend nichts anderes geregelt ist. Der Kunde setzt Agenten nicht gezielt zu ihrer Erhebung ein. Teilen Endnutzer solche Daten unaufgefordert mit, verarbeitet NexAI sie nur im Rahmen der Weisungen und Löschregeln dieses AVV. Beim NexAI Mailagent lässt sich nicht verhindern, dass eingehende Post solche Daten enthält, insbesondere Gesundheitsangaben in Krankmeldungen oder Bewerbungen; insoweit sind sie Gegenstand der beauftragten Verarbeitung. NexAI verarbeitet sie wie den übrigen Nachrichteninhalt zu den in Anlage A Ziffer 5.4 beschriebenen Zwecken und übermittelt sie dazu an den Anbieter des Sprachmodells (Anhang 2); der Mailagent sucht nicht gezielt nach ihnen und bildet aus ihnen keine Profile. Der Kunde prüft als Verantwortlicher, ob eine Ausnahme nach Art. 9 Abs. 2 DSGVO besteht. Postfächer, über die regelmäßig besondere Kategorien eingehen (etwa einer Personalabteilung, für Krankmeldungen oder eines Gesundheitsberufs), werden nur nach gesonderter Vereinbarung in Textform angebunden. Im NexAI Kalender können Vorher-Nachher-Fotos Gesundheitsbezug haben; die Funktion setzt eine ausdrückliche Einwilligung der betroffenen Person voraus, die der Kunde einholt.

§ 3a Berufsgeheimnisse

(1) Der Kunde sichert zu, dass er nicht zu den in § 203 Abs. 1 oder Abs. 2 StGB genannten Personen gehört und NexAI keine Daten überlässt, die einem solchen Berufsgeheimnis unterliegen. Ändert sich das, teilt er es NexAI vor der Überlassung in Textform mit.

(2) Für Kunden, die einem Berufsgeheimnis nach § 203 StGB unterliegen, erbringt NexAI den Voice Agent, [den Chat Agent] und den NexAI Mailagent nicht. Andere Leistungen erbringt NexAI für sie nur nach gesonderter Vereinbarung, in der NexAI sich zur Verschwiegenheit verpflichtet und die eingesetzten Unterauftragsverarbeiter ihrerseits zur Verschwiegenheit verpflichtet (§ 203 Abs. 3 Satz 2, Abs. 4 StGB).

§ 4 Weisungsbindung

(1) NexAI verarbeitet personenbezogene Daten ausschließlich auf **dokumentierte Weisung** des Kunden — auch in Bezug auf die Übermittlung personenbezogener Daten an ein Drittland —, es sei denn, NexAI ist nach Unionsrecht oder dem Recht eines Mitgliedstaats zur Verarbeitung verpflichtet (Art. 28 Abs. 3 lit. a DSGVO). In diesem Fall teilt NexAI dem Kunden diese rechtliche Anforderung vor der Verarbeitung mit, sofern das betreffende Recht eine solche Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet.

(2) Die maßgeblichen Weisungen sind in diesem AVV und den übrigen Vertragsdokumenten festgelegt (Erstweisung). Weitergehende Einzelweisungen erteilt der Kunde in Textform gegenüber der in § 14 genannten Kontaktstelle. Mündliche Weisungen bestätigt der Kunde unverzüglich in Textform.

(3) NexAI informiert den Kunden unverzüglich, wenn NexAI der Auffassung ist, dass eine Weisung gegen datenschutzrechtliche Vorschriften verstößt (Art. 28 Abs. 3 Unterabsatz 2 DSGVO). NexAI ist berechtigt, die Durchführung der betreffenden Weisung bis zu deren Bestätigung oder Änderung durch den Kunden auszusetzen.

(4) Der Kunde trägt die Verantwortung für die Rechtmäßigkeit der Weisungen und der Verarbeitung, insbesondere für das Vorliegen einer tragfähigen Rechtsgrundlage.

(5) **Weisungen über die Anwendung.** Stellt eine Anwendung dem Kunden Einstellungen zur Verfügung, insbesondere beim NexAI Mailagent die angebundenen Postfächer, die Personen und ihre Rechte, die Löschfristen, die Freigaberegeln und die Empfänger, an die ohne vorherige Freigabe gesendet werden darf, so ist jede Einstellung, die eine Person mit der Rolle Verwaltung vornimmt, eine dokumentierte Weisung des Kunden im Sinne von Art. 28 Abs. 3 Satz 2 Buchst. a DSGVO; Absatz (2) Satz 2 gilt insoweit nicht. Die Anwendung hält Person, Zeitpunkt und Inhalt jeder solchen Einstellung fest [setzt voraus für den bisherigen Inhalt und für die Aufbewahrung des geltenden Stands über 1.095 Tage hinaus: Erweiterung des Verwaltungsprotokolls]. Die Einstellungen wirken, ohne dass NexAI sie vorher prüft. Der Kunde stellt sicher, dass die Rolle Verwaltung nur Personen erhalten, die ihn insoweit vertreten dürfen. Absatz (3) bleibt unberührt, soweit NexAI davon Kenntnis erlangt, dass eine Einstellung gegen Datenschutzvorschriften verstößt.

§ 5 Vertraulichkeit

(1) NexAI verpflichtet die mit der Verarbeitung befassten Personen zur Vertraulichkeit, soweit sie nicht bereits einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen (Art. 28 Abs. 3 lit. b, Art. 29, Art. 32 Abs. 4 DSGVO).

(2) NexAI stellt sicher, dass Personen, die zur Verarbeitung der personenbezogenen Daten befugt sind, mit den einschlägigen datenschutzrechtlichen Anforderungen vertraut sind und Daten nur auf Weisung verarbeiten. Die Verpflichtung besteht auch nach Beendigung der Tätigkeit fort.

(3) Als Gesellschafter der NexAI GbR sind Maximilian Trenk und Jason Brian Merklein unmittelbar zur Vertraulichkeit verpflichtet.

§ 6 Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

(1) NexAI trifft die zur Gewährleistung eines dem Risiko angemessenen Schutzniveaus erforderlichen technischen und organisatorischen Maßnahmen nach Art. 32 DSGVO. Die zum Zeitpunkt des Vertragsschlusses getroffenen Maßnahmen sind in **Anhang 1 (Technische und organisatorische Maßnahmen)** beschrieben und sind Bestandteil dieses AVV.

(2) NexAI ist berechtigt, die Maßnahmen an den Stand der Technik und an geänderte tatsächliche Verhältnisse anzupassen, sofern das vereinbarte Schutzniveau nicht unterschritten wird. Wesentliche Änderungen dokumentiert NexAI und stellt sie dem Kunden auf Anfrage zur Verfügung.

(3) NexAI überprüft die Wirksamkeit der Maßnahmen in angemessenen Abständen.

§ 7 Zweckbindung, kein Modelltraining

(1) NexAI verarbeitet die personenbezogenen Daten des Kunden ausschließlich zu den in § 2 genannten Zwecken und nicht für eigene Zwecke.

(2) NexAI verwendet die im Auftrag verarbeiteten personenbezogenen Daten **nicht zum Training, zur Weiterentwicklung, zum Fine-Tuning oder zur Verbesserung eigener oder fremder KI-Modelle**.

(3) NexAI richtet die eingesetzten Dienste so ein, dass übermittelte Daten nicht zum Training verwendet werden. Speicherfristen bei den Diensten verkürzt NexAI, soweit der genutzte Tarif es erlaubt. Den Stand je Dienst (Training ausgeschlossen, Speicherdauer beim Dienst, Verarbeitungsregion) nennen Anhang 2 und Anhang 3; Änderungen teilt NexAI nach § 9 Abs. (2) mit. Soweit ein Subunternehmer Daten über die Erbringung der Leistung hinaus zu eigenen Zwecken verarbeitet, geschieht dies außerhalb des Auftragsverhältnisses; § 15 (Rollenmatrix) bleibt unberührt.

(4) Eine über die Auftragserfüllung hinausgehende Verarbeitung durch NexAI zu eigenen Zwecken – insbesondere zur Produktverbesserung – erfolgt nur nach Anonymisierung oder auf gesonderter, dokumentierter Rechtsgrundlage (Art. 28 Abs. 10 DSGVO).

§ 8 Speicherorte, Speicherdauer und Löschung

(1) Die Verarbeitung erfolgt teils intern bei NexAI, teils extern bei den in **Anhang 2 (Unterauftragsverarbeiter)** genannten Subunternehmern, ggf. auch in Drittländern nach Maßgabe von § 10.

(2) **Agenten** (Voice Agent, Chat Agent, Automatisierungen, individuelle KI-Agenten) verarbeiten Gesprächs- und Nachrichteninhalte grundsätzlich nur für die Dauer der jeweiligen Interaktion. Hält ein eingesetzter Dienst Inhalte oder Protokolle darüber hinaus vor und lässt sich das im genutzten Tarif abschalten oder verkürzen, schaltet NexAI es ab oder verkürzt es [setzt voraus beim Voice Agent: Abschaltung der Gesprächsprotokollierung beim Plattformanbieter]. Was sich nicht abschalten lässt, steht mit seiner Dauer in Anhang 3. Bei NexAI selbst gespeicherte Daten der Agenten werden spätestens sechs (6) Monate nach ihrer Erhebung gelöscht, sofern der Kunde keine kürzere Frist anweist.

(3) **Anwendungen** (NexAI CRM, NexAI Kalender, NexAI Mailagent, individuelle Anwendungen) sind das System, in dem der Kunde seine Daten führt. Die Daten bleiben dort, bis der Kunde sie löscht oder eine Löschregel greift. Die Löschregeln und ihre Vorgaben je Anwendung stehen in Anhang 3. Der Kunde bestimmt die Fristen als Verantwortlicher; Einstellungen in der Anwendung sind Weisungen nach § 4 Abs. (5). NexAI richtet die im Auftragsformular angegebenen Fristen ein, sonst gelten die Vorgaben aus Anhang 3. Wendet eine Anwendung eine Löschregel erst an, wenn der Kunde sie eingerichtet hat, weist NexAI bei der Einrichtung darauf hin. Beim NexAI Mailagent gelten die nach Anlage A Ziffer 5.4 Abs. (10) vereinbarten oder vom Kunden in der Anwendung eingestellten Fristen.

(4) Daten, deren Aufbewahrung der Kunde selbst schuldet (etwa Belege nach § 147 AO, § 14b UStG, § 257 HGB), bewahrt NexAI während der Vertragslaufzeit auf Weisung des Kunden in der Anwendung auf. § 12 bleibt unberührt.

(5) **Tonaufzeichnung und dauerhafte Speicherung von Gesprächsmitschriften** sind standardmäßig **deaktiviert**. Sie werden nur auf ausdrückliche, dokumentierte Weisung des Kunden aktiviert und stets mit der vertraglich vorgesehenen Pflicht-Ansage (KI-Hinweis sowie ggf. Aufzeichnungshinweis) verbunden. Der Kunde verantwortet die Rechtsgrundlage einer solchen Aufzeichnung.

(6) Gelöschte Daten verbleiben bis zum Ablauf der Sicherungsrotation (Anhang 3) in den verschlüsselten Datensicherungen und werden danach überschrieben. Nach einer Wiederherstellung aus einer Sicherung zieht NexAI zwischenzeitlich erledigte Löschungen nach.

§ 9 Unterauftragsverarbeiter

(1) Der Kunde erteilt NexAI die **allgemeine schriftliche Genehmigung** zur Beauftragung von Unterauftragsverarbeitern (Art. 28 Abs. 2 Satz 2 DSGVO). Die zum Zeitpunkt des Vertragsschlusses eingesetzten Subunternehmer sind in **Anhang 2 (Unterauftragsverarbeiter)** aufgeführt und werden hiermit genehmigt.

(2) NexAI informiert den Kunden über jede beabsichtigte Hinzuziehung oder Ersetzung eines Unterauftragsverarbeiters **mindestens vierzehn (14) Tage vorab in Textform** an den in § 14 benannten Datenschutzkontakt (Art. 28 Abs. 2 Satz 2 DSGVO). Die Mitteilung nennt Name, Anschrift, Leistung, Ort der Verarbeitung und Übermittlungsgrundlage.

(3) Ändert ein in Anhang 2 genannter Dienst seinerseits seine Unterauftragsverarbeiter, leitet NexAI dessen Mitteilung binnen drei Werktagen nach Eingang an den Kunden weiter; die Listen dieser Dienste sind, soweit veröffentlicht, in Anhang 2 genannt. Der Kunde kann binnen der ihm

verbleibenden Frist, mindestens aber binnen sieben Tagen nach der Weiterleitung widersprechen; NexAI macht den Widerspruch gegenüber dem Dienst geltend, soweit dessen Vertrag es zulässt.

(4) Der Kunde kann einer Änderung nach Absatz (2) oder (3) in Textform unter Angabe der datenschutzrechtlichen Gründe **widersprechen**. Im Fall eines berechtigten Widerspruchs bemühen sich die Parteien um eine einvernehmliche Lösung. Kann diese nicht gefunden werden und ist NexAI die Erbringung der betroffenen Leistung ohne den Subunternehmer nicht mit zumutbarem Aufwand möglich, steht jeder Partei ein **Sonderkündigungsrecht** hinsichtlich der betroffenen Leistung mit angemessener Frist zu.

(5) NexAI verpflichtet jeden Unterauftragsverarbeiter durch Vertrag oder anderes Rechtsinstrument auf Datenschutzpflichten, die den Pflichten dieses AVV im Wesentlichen entsprechen, insbesondere auf hinreichende Garantien nach Art. 28 Abs. 3 und Abs. 4 DSGVO. Kommt der Unterauftragsverarbeiter seinen Datenschutzpflichten nicht nach, haftet NexAI gegenüber dem Kunden für die Einhaltung dieser Pflichten.

(6) Nicht als Unterauftragsverarbeitung im Sinne dieser Regelung gelten Nebenleistungen, die NexAI als Nebenleistung in Anspruch nimmt (z. B. Telekommunikations-, Post-/Transport-, Wartungsleistungen), sofern dabei kein Zugriff auf die im Auftrag verarbeiteten Daten zum Zweck der Verarbeitung erfolgt.

§ 10 Drittlandtransfer

(1) NexAI übermittelt personenbezogene Daten nur an die in Anhang 2 genannten Empfänger in Drittländern; die Genehmigung nach § 9 Abs. (1) ist insoweit dokumentierte Weisung im Sinne des Art. 28 Abs. 3 Satz 2 Buchst. a DSGVO.

(2) Die Grundlage je Empfänger nennt Anhang 2: der Angemessenheitsbeschluss zum EU-U.S. Data Privacy Framework (Art. 45 DSGVO), soweit der Empfänger zertifiziert ist; sonst Standardvertragsklauseln nach Durchführungsbeschluss (EU) 2021/914 (Art. 46 Abs. 2 Buchst. c DSGVO), und zwar (a) Modul 3, soweit NexAI selbst an einen Unterauftragsverarbeiter im Drittland übermittelt (derzeit Vapi, Inc.), (b) die Klauseln zwischen der Gesellschaft in der EU und ihrer US-Gesellschaft, soweit NexAIs Vertragspartner in der EU sitzt und weiterübermittelt (derzeit OpenAI Ireland Limited und Anthropic Ireland, Limited; Google Ireland Limited, soweit eingesetzt).

(3) Für Übermittlungen auf Grundlage von Standardvertragsklauseln hat NexAI eine Bewertung nach Klausel 14 der Klauseln (Transfer Impact Assessment) erstellt und hält sie aktuell [setzt voraus: Bewertung für Vapi um das Gesprächsprotokoll beim Anbieter und Bewertung für Anthropic um die Verarbeitung von Kundenpost fortgeschrieben]. NexAI übermittelt dem Kunden auf Anfrage diese Bewertung und eine Kopie der Klauseln.

(4) NexAI stellt dem Kunden auf Anfrage Nachweise über die getroffenen Transfergarantien in geeigneter Form zur Verfügung.

§ 11 Unterstützungspflichten

11.1 Betroffenenrechte

(1) NexAI unterstützt den Kunden mit geeigneten technischen und organisatorischen Maßnahmen, soweit möglich, bei der Erfüllung von Anträgen betroffener Personen auf Wahrnehmung ihrer Rechte nach Art. 12–23 DSGVO (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch).

(2) Wendet sich eine betroffene Person unmittelbar an NexAI, leitet NexAI das Anliegen unverzüglich an den Kunden weiter und beantwortet es nicht selbständig, es sei denn, der Kunde weist dies an.

11.2 Meldung von Datenschutzverletzungen

(1) NexAI meldet dem Kunden jede Verletzung des Schutzes personenbezogener Daten **unverzüglich, spätestens jedoch innerhalb von vierundzwanzig (24) Stunden nach Kenntniserlangung**, in Textform an den in § 14 benannten Datenschutzkontakt des Kunden per E-Mail und zusätzlich telefonisch (Art. 33 Abs. 2 DSGVO).

(2) Die Meldung enthält, soweit verfügbar, eine Beschreibung der Art der Verletzung, die Kontaktdaten einer Anlaufstelle bei NexAI, die Kategorien und die ungefähre Zahl der betroffenen Personen und Datensätze, die wahrscheinlichen Folgen sowie die ergriffenen oder vorgeschlagenen Abhilfemaßnahmen. Soweit die Informationen nicht zeitgleich bereitgestellt werden können, dürfen sie ohne unangemessene weitere Verzögerung schrittweise nachgereicht werden.

(3) NexAI unterstützt den Kunden bei dessen Melde- und Benachrichtigungspflichten nach Art. 33 und Art. 34 DSGVO und ergreift angemessene Maßnahmen zur Eindämmung und Behebung.

11.3 Datenschutz-Folgenabschätzung

(1) NexAI unterstützt den Kunden unter Berücksichtigung der Art der Verarbeitung und der verfügbaren Informationen bei einer Datenschutz-Folgenabschätzung (Art. 35 DSGVO) sowie bei einer vorherigen Konsultation der Aufsichtsbehörde (Art. 36 DSGVO).

(2) Der Einsatz künstlicher Intelligenz zur Steuerung der Interaktion mit den Betroffenen oder zur Bewertung persönlicher Aspekte steht auf der Liste der Datenschutzkonferenz nach Art. 35 Abs. 4 DSGVO (Version 1.1 vom 17.10.2018, Nr. 11). Für den Voice Agent und den Chat Agent hat der Kunde danach eine Datenschutz-Folgenabschätzung durchzuführen, für den NexAI Mailagent wegen der Einstufung eingehender Nachrichten einschließlich des Tonfalls des Absenders voraussichtlich ebenfalls. Wer eine solche Verarbeitung vornimmt, muss nach § 38 Abs. 1 Satz 2 BDSG unabhängig von der Zahl der Beschäftigten einen Datenschutzbeauftragten benennen.

(3) NexAI stellt dem Kunden vor Inbetriebnahme unentgeltlich einen vorausgefüllten Baustein für die Folgenabschätzung bereit (Beschreibung der Verarbeitung, eingesetzte Dienste, Datenflüsse, von der Anwendung ausgehende Risiken, von NexAI getroffene Maßnahmen) und hält ihn bei wesentlichen Änderungen aktuell [setzt voraus für Chat Agent und NexAI Mailagent: Baustein erstellt]. Die Bewertung der Notwendigkeit und Verhältnismäßigkeit für die Zwecke des Kunden und das Ergebnis der Abschätzung obliegen dem Kunden.

11.4 Vergütung von Unterstützungsleistungen

Unterstützungsleistungen nach diesem § 11, die über den vertraglich geschuldeten Umfang hinausgehen und nicht auf einem NexAI zuzurechnenden Umstand beruhen, kann NexAI nach vorheriger Ankündigung zu den vereinbarten bzw., soweit nicht vereinbart, den üblichen Sätzen abrechnen. Die gesetzlich geschuldeten Grundunterstützungspflichten nach Art. 28 Abs. 3 DSGVO bleiben unentgeltlich.

§ 12 Löschung und Rückgabe nach Beendigung

(1) Nach Ende der Leistung stellt NexAI dem Kunden **dreißig (30) Tage** lang einen vollständigen **Export** bereit: strukturierte Daten als CSV/JSON und die in den Anwendungen abgelegten Dateien, insbesondere Belege als PDF und E-Rechnungen als XML, als gesondertes Paket. Der Kunde kann stattdessen die sofortige Löschung verlangen (Art. 28 Abs. 3 Satz 2 Buchst. g DSGVO).

(2) Nach Ablauf der Frist oder nach bestätigtem Erhalt des Exports löscht NexAI alle Daten des Kunden in den eigenen Systemen und veranlasst die Löschung bei den Unterauftragsverarbeitern, soweit dort noch Daten liegen (etwa Assistenten, Gesprächsprotokolle, gespeicherte Zugänge). Zugangsschlüssel zu Konten des Kunden werden zusätzlich widerrufen.

(3) In verschlüsselten Datensicherungen verbleiben Daten bis zum Ablauf der Rotation nach Anhang 3. Wird aus einer solchen Sicherung wiederhergestellt, zieht NexAI zwischenzeitlich erledigte Löschungen nach, einschließlich der Löschung der Daten ausgeschiedener Kunden.

(4) NexAI übersendet nach Abschluss der Löschung unaufgefordert eine **Löschbestätigung** in **Textform** mit den gelöschten Systemen und dem Datum.

(5) Aufbewahrungspflichten des Kunden (insbesondere § 147 AO, § 14b UStG, § 257 HGB) erfüllt der Kunde mit dem Export nach Absatz (1). Eine Aufbewahrung durch NexAI über das Vertragsende hinaus erfolgt nur nach gesonderter Vereinbarung über Dauer, Zugriff und Vergütung.

(6) Beim NexAI Mailagent gehört zur Beendigung auch die Beendigung des Zugriffs auf die Postfächer des Kunden. Mit dem Ende der Leistungserbringung ruft NexAI aus den Postfächern des Kunden nichts mehr ab und versendet nichts mehr. NexAI löscht unverzüglich, spätestens binnen sieben Tagen, alle bei NexAI hinterlegten Zugangsmittel für die Postfächer des Kunden, insbesondere App-Passwörter und Erneuerungstoken, sowie eine für den Kunden eingerichtete Anwendungsregistrierung oder ein für ihn eingerichtetes Dienstkonto samt Geheimnis, und bestätigt dies in der Löschbestätigung nach Absatz (4) mit Zeitpunkt. Dasselbe gilt für ein einzelnes Postfach, sobald der Kunde dessen Anbindung in der Anwendung trennt oder es aus dem Auftragsformular streicht.

(7) Eine vom Kunden in seinem Konto beim Postfachanbieter erteilte Zustimmung oder Delegierung zugunsten einer Anwendung von NexAI bleibt bestehen, bis der Kunde sie dort entfernt; NexAI kann sie nicht entfernen. NexAI übermittelt dem Kunden mit der Löschbestätigung eine Anleitung zur Entfernung. Der Kunde entfernt die Zustimmung oder Delegierung unverzüglich nach Beendigung; bis dahin nutzt NexAI sie nicht.

§ 13 Nachweis- und Kontrollrechte (Audit)

(1) NexAI stellt dem Kunden alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten aus Art. 28 DSGVO zur Verfügung und ermöglicht Überprüfungen – einschließlich Inspektionen –, die vom Kunden oder einem von diesem beauftragten Prüfer durchgeführt werden, und trägt zu diesen bei (Art. 28 Abs. 3 lit. h DSGVO).

(2) Der Nachweis kann durch geeignete Dokumentation, aktuelle Testate, Zertifizierungen oder Berichte unabhängiger Stellen erbracht werden. Reichen diese zur Ausräumung eines konkreten Prüfbedarfs nicht aus, kann der Kunde nach rechtzeitiger Vorankündigung (in der Regel mindestens vierzehn (14) Tage vorab) und zu üblichen Geschäftszeiten eine Vor-Ort-Prüfung durchführen, ohne den Betriebsablauf unverhältnismäßig zu beeinträchtigen und unter Wahrung

der Vertraulichkeit sowie der Rechte Dritter.

(3) Der beauftragte Prüfer darf nicht in einem Wettbewerbsverhältnis zu NexAI stehen und ist zur Vertraulichkeit zu verpflichten.

(4) Prüfungen, die über eine (1) reguläre Prüfung pro Jahr hinausgehen oder auf Verlangen des Kunden ohne konkreten Anlass erfolgen, kann NexAI den hierdurch entstehenden angemessenen Aufwand zu den üblichen Sätzen in Rechnung stellen. Prüfungen aus konkretem Anlass sowie die gesetzlich geschuldete Bereitstellung von Nachweisen bleiben hiervon unberührt.

§ 14 Datenschutzbeauftragter, Verzeichnis, Kontaktstelle

(1) Datenschutzbeauftragter von NexAI ist [Name, Anschrift, E-Mail; Benennung nach § 38 Abs. 1 Satz 2 BDSG erforderlich]. Kontaktstelle für Datenschutzangelegenheiten und für Weisungen nach § 4 Abs. (2) ist mbt@nex-a-i.com; telefonische Anlaufstelle für Meldungen nach § 11.2 ist 0176 80714816.

(2) NexAI führt ein Verzeichnis aller Kategorien von im Auftrag durchgeführten Verarbeitungstätigkeiten (Art. 30 Abs. 2 DSGVO).

Datenschutzkontakt des Kunden (Name, E-Mail):

_____

§ 15 Rollenmatrix nach Leistungsart

Die datenschutzrechtliche Rolle von NexAI richtet sich nach der jeweils beauftragten Leistung. Die im Auftragsformular je Leistung getroffene Zuordnung ist maßgeblich; im Zweifel gilt die nachstehende Matrix:

Leistung / Agent	Rolle NexAI	Rechtsrahmen
Voice Agent (eingehend)	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
Voice Agent (ausgehend, vom Kunden veranlasste Ansprache)	Auftragsverarbeiter; die Zulässigkeit der Ansprache verantwortet der Kunde	Art. 28 DSGVO / dieser AVV; § 15 des Rahmenvertrages
Chat Agent	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
Automatisierungen	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
Individuelle KI-Agenten	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
NexAI CRM	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
NexAI Kalender	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
NexAI App / individuelle Anwendungen	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
NexAI Mailagent	Auftragsverarbeiter	Art. 28 DSGVO / dieser AVV
Anwendungen als Kauflizenz (Betrieb beim Kunden)	Auftragsverarbeiter nur bei Wartungs- und Supportzugriffen; im Übrigen keine Verarbeitung durch NexAI	Art. 28 DSGVO / dieser AVV; Anlage E

(1) NexAI verarbeitet die in den Anwendungen gespeicherten Daten ausschließlich weisungsgebunden für den Kunden und nicht für eigene Zwecke. Eine Recherche oder Beschaffung von Kontaktdaten durch NexAI ist nicht Gegenstand der Leistungen (Anlage A, Ziffer 14).

(2) Setzt der Kunde einen Agenten für ausgehende Ansprache oder Direktwerbung ein, bleibt NexAI Auftragsverarbeiter; die Rechtmäßigkeit der Ansprache und die Erfüllung der Informationspflichten nach Art. 13 und 14 DSGVO verantwortet der Kunde (§ 15 des Rahmenvertrages).

(3) Die Klarstellung in § 1 Abs. 5 (eigene Verantwortlichkeit von NexAI) bleibt unberührt.

(4) Beim NexAI Mailagent verarbeitet NexAI die Korrespondenz des Kunden ausschließlich weisungsgebunden. Der Kunde verantwortet die Rechtsgrundlage für das Lesen, Auswerten und Aufbewahren der Korrespondenz sowie die Information der betroffenen Personen; NexAI stellt die dafür erforderlichen Angaben bereit. NexAI verwendet Inhalte der Korrespondenz weder zur Verbesserung der Anwendung noch für andere Kunden. Mitarbeiter von NexAI greifen auf Inhalte der Korrespondenz nur zu, soweit es zur Behebung einer Störung erforderlich ist; NexAI dokumentiert jeden solchen Zugriff mit Anlass.

§ 16 Haftung und Innenausgleich

(1) Für die Haftung im Außenverhältnis gegenüber betroffenen Personen gilt Art. 82 DSGVO. Im Innenverhältnis tragen die Parteien einen etwaigen Schaden bzw. eine Geldbuße nach dem **Maß ihres jeweiligen Verantwortungsanteils** an dem zugrunde liegenden Verstoß (Art. 82 Abs. 5 DSGVO).

(2) Hat eine Partei an eine betroffene Person Schadensersatz geleistet, der über ihren Verantwortungsanteil hinausgeht, kann sie von der anderen Partei den auf deren Anteil entfallenden Teil zurückfordern.

(3) Die übrigen Haftungsregelungen des Rahmenvertrags (dort § Haftung/Haftungsbeschränkung) gelten für das Verhältnis der Parteien untereinander ergänzend, soweit sie zwingendem Datenschutzrecht nicht entgegenstehen.

§ 17 Schlussbestimmungen

(1) Änderungen und Ergänzungen dieses AVV bedürfen der Textform. Dies gilt auch für die Aufhebung dieses Textformerfordernisses. Vorrangige Individualabreden (§ 305b BGB) bleiben unberührt.

(2) Sollte eine Bestimmung dieses AVV unwirksam sein oder werden, bleibt die Wirksamkeit der übrigen Bestimmungen unberührt.

(3) Es gilt das Recht der Bundesrepublik Deutschland unter Ausschluss des UN-Kaufrechts. Ausschließlicher Gerichtsstand für alle Streitigkeiten aus oder im Zusammenhang mit diesem AVV ist – soweit gesetzlich zulässig – der Sitz von NexAI.

(4) Die Anhänge 1 (TOM), 2 (Unterauftragsverarbeiter) und 3 (Speicher- und Löschfristen) sind Bestandteil dieses AVV.

Anhang 1 Technische und organisatorische Maßnahmen (Art. 32 DSGVO)

Die Maßnahmen gelten für die Systeme, die NexAI selbst betreibt. Bei Anwendungen, die der Kunde als Kauflizenz selbst betreibt, trifft der Kunde die Maßnahmen für seine Infrastruktur (Anlage E).

1. Für alle Systeme

- Betrieb der von NexAI selbst betriebenen Systeme auf Servern der Hetzner Online GmbH in Rechenzentren in Deutschland;
- Übertragung personenbezogener Daten ausschließlich verschlüsselt (TLS);
- Serverzugang nur für die Gesellschafter [per SSH-Schlüssel – bestätigen];
- Zugänge zu den Verwaltungsoberflächen der Unterauftragsverarbeiter mit Zwei-Faktor-Anmeldung [bestätigen je Dienst];
- rollenbasierte, auf das Erforderliche beschränkte Berechtigungen; Entzug nicht mehr benötigter Berechtigungen;
- logische Trennung der Datenbestände je Kunde; keine kundenübergreifende Zusammenführung;
- Überprüfung der Maßnahmen mindestens jährlich und bei jeder wesentlichen Änderung.

2. NexAI CRM (bei Betrieb durch NexAI)

- Trennung der Mandanten in der Datenbank durch Zeilensicherheit je Mandant; die Anwendung arbeitet mit einer Datenbankrolle ohne Administratorrechte;
- Passwörter als argon2id-Prüfsumme; Sitzungen serverseitig, Sitzungskennung nur als Abdruck, Ablauf nach 12 Stunden; Zwei-Faktor-Anmeldung, für Administratoren verpflichtend;
- AES-256-GCM-Feldverschlüsselung für Gesprächsmitschriften, Zugangsschlüssel angebundener Konten und Zwei-Faktor-Geheimnisse; übrige Inhalte liegen unverschlüsselt in der Datenbank;
- Änderungsprotokoll, das die Anwendung weder ändern noch löschen kann; Ziele ausgehender Webhooks gegen interne Adressen gesperrt;
- tägliche, verschlüsselte Sicherung der Datenbank; aufbewahrt werden die jeweils letzten 30 Sicherungen; die Sicherungen liegen derzeit auf dem Server, auf dem das CRM betrieben wird, und schützen nicht gegen einen Totalverlust dieses Servers [setzt voraus für eine Sicherung auf einem getrennten System: Auslagerung auf ein getrenntes System in Deutschland und monatliche automatische Rückspielprobe].

3. NexAI Kalender

- Passwörter als bcrypt-Prüfsumme, Sitzungskennung nur als Abdruck, Begrenzung der Anmeldeversuche, Zwei-Faktor-Anmeldung mit Wiederherstellungscodes verfügbar;
- Belege durch Datenbankauslöser gegen Änderung und Löschung gesperrt; täglicher Löschlauf (Anhang 3);
- nächtliche, verschlüsselte Sicherung auf einen zweiten, vom Produktivsystem getrennten Server; aufbewahrt werden die jeweils letzten 30 Sicherungen; vor dem Verschlüsseln wird jeder Abzug probeweise in eine leere Datenbank eingespielt und Tabelle für Tabelle nachgezählt [Server je Kunde und Sicherung für die Instanz des Kunden – bestätigen].

4. NexAI Mailagent

- je Kunde eigener Prozess, eigene mit SQLCipher verschlüsselte Datenbank, eigener Schlüssel und eigener Datenordner;
- Anmeldung mit Passwort und zweitem Faktor; der zweite Faktor ist für Personen mit der Rolle Verwaltung verpflichtend und für alle übrigen Personen verfügbar;

- Versand nur nach Freigabe durch einen Menschen, Ausnahme nur der vereinbarte selbsttätige Versand (Anlage A Ziffer 5.4 Abs. (1)); Vier-Augen-Freigabe nach den vereinbarten Schwellen; verkettetes Freigabeprotokoll; Inhalte eingehender Nachrichten werden nie als Anweisung ausgeführt;
- täglicher Löschlauf nach Anhang 3 [setzt voraus: Löschlauf in der Instanz des Kunden scharf geschaltet];
- nächtliche, verschlüsselte Sicherung auf einen zweiten, vom Produktivsystem getrennten Server; aufbewahrt werden die jeweils letzten 14 Sicherungen [setzt voraus: Sicherung für die Instanz des Kunden eingerichtet; heute nur für die NexAI-eigene Instanz].

5. Agenten

- Tonaufzeichnung beim Plattformanbieter des Voice Agent abgeschaltet [setzt voraus: auch der Verbindungsmitschnitt (SIP/pcap) abgeschaltet]; Gesprächsprotokolle beim Plattformanbieter nach Anhang 3;
- Automatisierungen auf selbst betriebenem n8n bei Hetzner; Zugangsdaten zu Kundendiensten dort verschlüsselt gespeichert;
- Sprachmodelle vertraglich ohne Training.

6. Anmeldung des NexAI Mailagent an den Postfächern des Kunden

- Die Anmeldung erfolgt mit einem vom Kunden bereitgestellten Anwendungspasswort oder, soweit NexAI es für den Postfachanbieter bereitstellt, über dessen Anmeldeverfahren (OAuth 2.0) durch Anmeldung einer berechtigten Person oder Zustimmung eines Administrators des Kunden;
- Anwendungspasswörter und Erneuerungstoken liegen verschlüsselt in der Datenbank der Instanz des Kunden;
- für jeden Kunden verwendet NexAI eine eigene Anwendungsregistrierung bzw. ein eigenes Dienstkonto mit eigenem Geheimnis [setzt voraus: je Kunde eingerichtet];
- der Zugriff ist auf die im Auftragsformular benannten Postfächer beschränkt; bei Microsoft 365 berechtigt der Administrator des Kunden jedes Postfach einzeln; bei der domänenweiten Delegierung von Google erfasst die Berechtigung technisch alle Nutzer der Domäne, die Anwendung fordert Zugriff nur für die benannten Postfächer an;
- Erteilung, Umfang und Entfernung der Berechtigung im Konto des Kunden liegen beim Kunden; NexAI stellt dafür eine Anleitung bereit.

7. Organisation

- Verpflichtung der beteiligten Personen auf Vertraulichkeit;
- vertragliche Bindung der Unterauftragsverarbeiter auf entsprechende Schutzpflichten;
- dokumentierte Weisungslage; Verzeichnis der Verarbeitungstätigkeiten (Art. 30 Abs. 2 DSGVO).

Anhang 2 Unterauftragsverarbeiter

Die folgenden Unterauftragsverarbeiter sind zum Zeitpunkt des Vertragsschlusses eingesetzt und werden vom Kunden allgemein genehmigt (§ 9). Der konkrete Einsatz richtet sich nach den beauftragten Agenten und Anwendungen. Nicht bei jedem Kunden kommen sämtliche Dienste zum Einsatz.

Name	Sitz / Land	Leistung	Datenkategorien	Transfermechanismus
Hetzner Online GmbH	Industriestraße 25, 91710 Gunzenhausen; Rechenzentren in Deutschland	Hosting und Betrieb der von NexAI selbst betriebenen Systeme (Automatisierungen/n8n, NexAI CRM bei Betrieb durch NexAI, NexAI Kalender, NexAI Mailagent einschließlich nächtlicher verschlüsselter Sicherung, NexAI App) und Ablage der Sicherungen	je nach Leistung: Kontakt-, Vorgangs-, Termin-, Aufgaben-, Beleg- und Protokolldaten; beim NexAI Mailagent zusätzlich gespiegelte Nachrichten samt Anhängen, Entwürfe, Freigabeprotokoll und Anmeldedaten der Nutzer des Kunden	kein Drittland; AVV nach Art. 28 DSGVO
Vapi, Inc.	San Francisco, USA [Postanschrift laut Vapi-DPA]	Gesprächssteuerung, Telefonie-Orchestrierung, Sprachausgabe (Voice Agent)	Gesprächsinhalte, Metadaten, Rufnummern	kein DPF; EU-SCC Modul 3 + Zusatzmaßnahmen + TIA; Liste weiterer Auftragsverarbeiter: security.vapi.ai
Soniox, Inc.	1045 Helm Ln, Foster City, CA 94404, USA	Spracherkennung als Unterauftragsverarbeiter von Vapi (Voice Agent)	Audio-/Sprachdaten, daraus erzeugte Wortprotokolle, Metadaten	kein DPF; Weiterübermittlung im Rahmen der SCC zwischen NexAI und Vapi und des Vertrags zwischen Vapi und Soniox
OpenAI Ireland Limited (Vertragspartner); OpenAI, L.L.C., USA	1st Floor, The Liffey Trust Centre, 117–126 Sheriff Street Upper, Dublin 1, D01 YC43, Irland; OpenAI, L.L.C., San Francisco, USA [Anschrift prüfen]	Sprachmodell (Chat Agent, Automatisierungen; Voice Agent, soweit über das Konto von NexAI)	Gesprächs- und Textinhalte, Metadaten	kein DPF; Weiterübermittlung an OpenAI, L.L.C. auf Grundlage der EU-SCC; vertraglich kein Training; Speicherung bis 30 Tage zur Missbrauchserkennung (Anhang 3)

Name	Sitz / Land	Leistung	Datenkategorien	Transfermechanismus
Anthropic Ireland, Limited (Vertragspartner); Anthropic, PBC, USA (konzerninterner weiterer Auftragsverarbeiter)	6th Floor, South Bank House, Barrow Street, Dublin 4, D04 TR29, Irland; Verarbeitung durch Anthropic, PBC in den USA und in Rechenzentren von Google Cloud, Amazon Web Services und Microsoft Azure (Ort laut Anthropic: weltweit)	Sprachmodell im NexAI Mailagent (Einstufung, Antwortentwürfe, Übersetzung, Zusammenfassung verlinkter Seiten)	Inhalte eingehender und gesendeter Nachrichten samt Anhängen, Metadaten	kein DPF (geprüft 17.10.2026); Übermittlung in die USA auf Grundlage der EU-SCC nach dem Anthropic-DPA + Zusatzmaßnahmen + TIA; vertraglicher Ausschluss des Trainings; Liste: trust.anthropic.com/subprocessors
Amazon Web Services EMEA SARL (Vertragspartner); Amazon Web Services, Inc. (Partei des AWS-DPA)	38 Avenue John F. Kennedy, L-1855 Luxemburg; Amazon Web Services, Inc., 410 Terry Avenue North, Seattle, WA 98109-5210, USA. Verarbeitung ausschließlich in AWS-Rechenzentren in Mitgliedstaaten der EU über das geografische EU-Inferenzprofil von Amazon Bedrock	Sprachmodelle (Claude, Hersteller Anthropic) über Amazon Bedrock im NexAI Mailagent; eingesetzt erst nach Freischaltung und Mitteilung nach § 9 Abs. (2); der Modellhersteller erhält keine Daten	Inhalte eingehender und gesendeter Nachrichten samt Anhängen, Metadaten	keine Drittlandübermittlung vorgesehen; für Zugriffe aus Drittländern im Ausnahmefall EU-SCC Modul 3 nach dem AWS-DPA; Amazon Web Services, Inc. DPF-zertifiziert (geprüft 17.10.2026); Liste: aws.amazon.com/compliance/sub-processors
Google Ireland Limited; Google LLC	Gordon House, Barrow Street, Dublin 4, Irland; 1600 Amphitheatre Parkway, Mountain View, CA 94043, USA	nur soweit NexAI für den Kunden Google-Dienste unter eigenem Konto einsetzt (Versand von Bestätigungen, Kalender) [Einsatz klären]	Termin-, Kontakt-, Vorgangsdaten, Metadaten	DPF (Google LLC), ergänzend EU-SCC
Plus Five Five, Inc. (Resend)	2261 Market Street #5039, San Francisco, CA 94114, USA; Versand aus der EU-Region (Irland)	Versand von System-E-Mails aus den Anwendungen (Bestätigungen, Erinnerungen, Benachrichtigungen)	E-Mail-Adresse, Name, Inhalt der Nachricht	DPF; ergänzend EU-SCC Modul 3 im Resend-DPA

Name	Sitz / Land	Leistung	Datenkategorien	Transfermechanismus
seven communications GmbH & Co. KG	Willestraße 4–6, 24103 Kiel	Versand von SMS (Kalender, CRM); nur bei beauftragtem SMS-Versand	Rufnummer der Empfängerin bzw. des Empfängers, Inhalt der Nachricht	kein Drittland; AVV nach Art. 28 DSGVO

Die aufgeführten Unterauftragsverarbeiter setzen ihrerseits weitere Auftragsverarbeiter ein, insbesondere Konzerngesellschaften und Rechenzentrumsbetreiber; maßgeblich sind deren veröffentlichte Listen (Spalte Transfermechanismus). Diese weiteren Auftragsverarbeiter sind von der Genehmigung nach § 9 Abs. (1) umfasst; für ihre Änderung gilt § 9 Abs. (3).

Empfänger ohne Auftragsverarbeitung (Telekommunikation, § 9 Abs. (6)): easybell GmbH, Brückenstraße 5a, 10179 Berlin – SIP-Anschluss, sofern so eingerichtet; Deutschland.

Keine Unterauftragsverarbeiter von NexAI (vom Kunden selbst beauftragt; NexAI greift nur auf Weisung zu): Postfach- und Kalenderanbieter des Kunden (z. B. Google, Microsoft, andere IMAP-Anbieter), vom Kunden eingetragene Rückruf-Adressen und Kalender-Abos sowie die eigenen Systeme des Kunden einschließlich seiner Infrastruktur bei der Kauflizenz.

Ergänzende / abweichende Subunternehmer (kundenspezifisch):

Sitzangaben und Transfermechanismen können sich ändern; maßgeblich ist die jeweils aktuelle, dem Kunden nach § 9 Abs. (2) mitgeteilte Fassung. Angaben in eckigen Klammern sind vor Verwendung zu prüfen bzw. zu ergänzen.

Anhang 3 Speicher- und Löschfristen

Stand Oktober 2026. Die Fristen der Anwendungen stammen aus dem Code, der löscht; die Fristen bei Diensten aus deren Bedingungen bzw. der Einstellung bei NexAI. „Vorgabe“ heißt: gilt, solange der Kunde in der Anwendung oder im Auftragsformular nichts anderes bestimmt.

System	Daten	Frist
Voice Agent (Plattformanbieter Vapi)	technisches Gesprächsprotokoll	bis zu [14] Tage beim Anbieter; Anrufübersicht mit Rufnummern: [Frist beim Anbieter klären]
Chat Agent, Automatisierungen, Voice Agent (OpenAI)	Ein- und Ausgaben des Sprachmodells	bis zu 30 Tage beim Anbieter zur Missbrauchserkennung, solange keine Null-Speicherung vereinbart ist
Automatisierungen (n8n)	Ausführungsprotokolle	höchstens 6 Monate [setzt voraus: Aufbewahrung der Ausführungsdaten in n8n entsprechend eingestellt]
NexAI Mailagent (Anthropic)	Ein- und Ausgaben des Sprachmodells	[Dauer laut Bedingungen des Anbieters prüfen]
NexAI CRM	Kontakte, Leads, Termine, Anrufe, Notizen, Mails, Anhänge	Löschregel je Datenart, vom Kunden im Datenschutz-Center gesetzt; ohne Regel keine automatische Löschung
NexAI CRM	Gesprächsmitschriften aus dem Voice Agent	bei der Übergabe wählbar (24 Stunden, 7 oder 30 Tage); ohne Wahl keine automatische Löschung
NexAI CRM	Änderungsprotokoll	12 Monate; Einträge zu Auskunfts- und Löschanträgen bis zum Ende des dritten Jahres nach dem Eintragsjahr; Einträge zur Abrechnung bis zum Ende des zehnten Jahres
NexAI CRM	festgeschriebene Belege	unveränderbar bis Vertragsende, danach § 12
NexAI Kalender	Stammdaten der Kundschaft	Anonymisierung 24 Monate nach dem letzten Termin (Vorgabe, je Betrieb einstellbar)
NexAI Kalender	Zähler gegen Missbrauch (mit IP-Adresse)	7 Tage
NexAI Kalender	Änderungsprotokoll	24 Monate
NexAI Kalender	Nachrichtenausgang (versandte SMS und E-Mails)	6 Monate

System	Daten	Frist
NexAI Kalender	Belege	acht Jahre ab Schluss des Kalenderjahres des Belegs, danach Löschung
NexAI Kalender	Terminumfragen	30 Tage nach der Entscheidung bzw. nach dem letzten Vorschlag
NexAI Kalender	Urlaub und Abwesenheiten des Personals	genehmigte drei Jahre nach ihrem Ende, abgelehnte und zurückgezogene 6 Monate
NexAI Mailagent	Nachrichten samt Auswertung	Vorgabe 180 Tage
NexAI Mailagent	Anhänge; verworfene Entwürfe	Vorgabe je 90 Tage
NexAI Mailagent	Wortlaut im Freigabeprotokoll; Verwaltungsprotokoll	Vorgabe je 1.095 Tage
NexAI Mailagent	übrige Angaben einer Zeile im Freigabeprotokoll	6 volle Kalenderjahre nach dem Jahr der Freigabe
NexAI Mailagent	Tagesübersichten	wie Nachrichten (Vorgabe 180 Tage)
NexAI Mailagent	Schleifenschutz der Automatik (Empfänger, Betreff und Message-ID selbsttätig versandter Antworten)	wie Nachrichten (Vorgabe 180 Tage)
NexAI Mailagent	gespeicherte Bankverbindungen bekannter Absender (Betrugserkennung)	24 Monate nach der letzten Nennung, nicht änderbar
Datensicherungen	Sicherungsstände	CRM 30, Kalender 30, Mailagent 14 Stände; gelöscht wird nach Anzahl, nicht nach Alter

Für den NexAI Mailagent gelten die Fristen der Instanz des Kunden erst, wenn dort der Löschlauf scharf geschaltet ist [setzt voraus: Löschlauf in jeder Kundeninstanz scharf geschaltet].

Unterschriften

Die Parteien schließen diesen Vertrag zur Auftragsverarbeitung einschließlich seiner Anhänge 1 bis 3 verbindlich ab.

Für die Unterschrift für NexAI durch bevollmächtigte Personen gilt der Hinweis zur Unterschrift in Ziffer 16 des Leistungsscheins.

Für NexAI	**Für den Kunden**
Ort, Datum	Ort, Datum
Name, Funktion (Gesellschafter oder in Vollmacht für NexAI)	Name / Funktion

Fassung Oktober 2026. Entwurf, von NexAI erstellt; die anwaltliche Prüfung folgt. Eckige Klammern kennzeichnen Werte und Regelungen, die vor Verwendung festzulegen sind; „[setzt voraus: …]“ kennzeichnet Zusagen, die erst gelten, wenn die genannte technische Voraussetzung erfüllt ist.